

Learn MAY 09, 2025 | 8 MINUTE READ

Using ISO/IEC 27001 for Information Security Management Systems (ISMS) Excellence

By [Joseph Nduhiu](#)

In their [2025 Global Cybersecurity Outlook](#), the World Economic Forum highlighted the growing complexity of cyberspace. This complexity is fueled by:

- Escalating geopolitical tensions
- Dependency on intricate supply chains
- Rapid adoption of emerging technologies like generative AI
- An increasing array of regulatory requirements
- A widening cyber skills gap

These challenges signal that the information age is here to stay, demanding a proactive approach to cybersecurity. To navigate these risks, leaders in both private and public sectors need a security-first mindset.

One critical tool to achieve this is deploying an [Information Security Management System](#) (ISMS) — a structured framework that strengthens security and resilience across key organizational touchpoints. For over 20 years, ISO/IEC 27001 has been the global standard for designing and implementing an ISMS, enabling organizations to manage information security risks effectively.

In this article, we will explore what ISO/IEC 27001 entails, its core principles, and how organizations can leverage it to enhance their cybersecurity posture.

Let's begin!

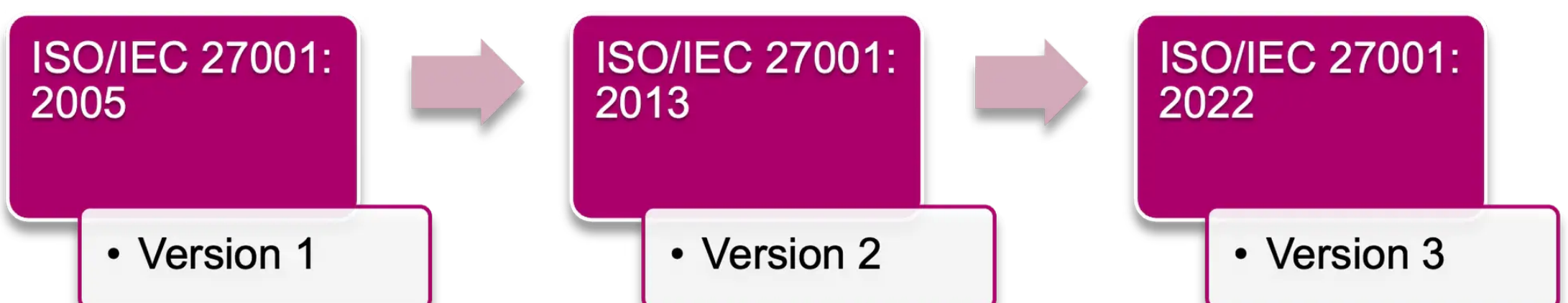
What is ISO/IEC 27001?

Established by the International Organization for Standardization ([ISO](#)) and the International Electrotechnical Commission ([IEC](#)), ISO/IEC 27001 is the most widely recognized standard in the ISO/IEC 27000 family, which includes over 20 standards on:

- Information security ([InfoSec](#))
- Cybersecurity
- Privacy

Now in its third iteration, it guides organizations in establishing, implementing, and continuously improving an information security management system (ISMS). This system aids in managing risks related to the security of data owned or handled by the organization in whatever format i.e. paper, tape, or digital etc.

Since its first publication in 2005, ISO/IEC 27001 has evolved to address emerging cyber threats and new regulations.



ISO/IEC 27001 was established based on the [three principles of the CIA triad](#). These are:

Integrity means that the information in custody of the authorized persons should be accurate and consistent and reliable.

Risk example: A bug in a stock exchange trading software erases the last two years of your stock portfolio transactions.

Availability

Availability means that Information should be readily available to the authorized persons when they need it.

Risk example: A ship accidentally drops its anchor on undersea fiber cables leading to an internet outage in your country.

The role of ISMS

An ISMS that meets the requirements of ISO/IEC 27001 preserves the confidentiality, integrity and availability of information by applying [a risk management process](#) and gives confidence to interested parties that risks are adequately managed. By implementing an ISMS based on ISO/IEC 27001, organizations can:

- Prepare people, processes, and technology to face evolving cybersecurity threats by having the right approach to securing information assets.
- Demonstrate compliance to required regulatory requirements such as the [EU GDPR](#).

An important clarification that's needed here is that [information security \(InfoSec\)](#) is the focus of ISO/IEC 27001 — not the wider tech or security industries. This is because in whatever form it comes, information is vital, whether it's technical information or personal or financial. This means that any organization or company, in any industry, can be certified with ISO/IEC 27001 as the ISMS is designed to secure information in all forms, including paper-based, cloud-based, and digital data.

(Related reading: [security compliance explained](#).)

How does ISO/IEC 27001 work?

At the core of ISO/IEC 27001 is identifying, evaluating, and treating risks around the organization's valuable information in whatever form whether physical, electronic, or even verbal. These risks are identified and assessed based on:

- The organization's overall business strategy and objectives
- Governance requirements from the organization and its stakeholders

These risks are addressed by measures or safeguards to modify or maintain them. These safeguards are referred to as [controls](#) within the ISO/IEC 27001 framework, and organizations have the liberty to specify the relevant controls they'll implement based on the risk assessment, in a document called the Statement of Applicability (SoA).

While ISO/IEC 27001 spells out the requirements for an ISMS, there are several standards that can provide guidance in meeting these requirements in accordance with an organization's context. They include:

- [ISO/IEC 27002:2022](#) Reference for determining and implementing controls in an ISMS
- [ISO/IEC 27005:2022](#) Guidance on information risk assessment and treatment
- [ISO/IEC TR 27016:2014](#) Guidance on decisions and economic consequences of investing in an ISMS

When it comes to the *how* of conducting risk assessment and subsequent treatment through controls, organizations are not restricted to ISO standards. To implement an ISMS meet the requirements of ISO/IEC 27001, orgs can also reference other guidance such as:

- The [NIST Cybersecurity Framework](#)
- CISA's [Cyber Essentials Starter Kit](#)
- [ITIL 4 Information Security Management](#) practice guide
- The UK's [Cyber Essentials](#) certification

([Learn more about these and other cybersecurity frameworks](#).)

Structure of ISO/IEC 27001

The ISO/IEC 27001:2022 standard requirements are spelled out in the standard's clauses 4-10, while the specific controls are listed in Annex A.

Clauses 4-10

The ISO/IEC 27001 requirements for establishing and implementing an ISMS are outlined as follows:

Clause 4 Context of the organization: Here the internal and external issues as well as needs of interested parties are identified. This information is used to inform the scope of the ISMS and guide its establishment based on ISO/IEC 27001 requirements.

Clause 5 Leadership: The requirements here involve the organization's top management who have to demonstrate their commitment to the establishment, maintenance, and improvement of the ISMS. This includes:

- Outline measurable information security objectives which align to the organization’s mandate and plan actions to achieve them.

Any changes to the ISMS should also be conducted in a structured manner.

Clause 7 Support: This clause considers what the organization should put in place for the ISMS to work including resources of all types:

- Ensure that people resources are competent and aware of their information security responsibilities.
- Communicate with the ISMS stakeholders in a structured manner.
- Standardize and maintain documented information throughout the [information lifecycle](#).

Clause 8 Operation: Here, the ISMS is realized through the organization’s processes which should be defined, executed, and controlled. At planned intervals or when the operational context changes, the organization performs the risk assessment and treatment activities as per the approach defined in clause 6.

Clause 9 Performance Evaluation: To ensure the ISMS meets the set objectives, the organization should monitor, measure, analyze, and evaluate the performance of its processes and controls. Internal audits and management reviews should also be conducted to assure stakeholders that the ISMS is effective.

Clause 10 Improvement: To improve the ISMS, the organization addresses any non-conformities found in its processes and controls during audits, while also identifying and implementing any improvements to enhance its information security posture.

Annex A

It’s in Annex A we find the 93 different security controls mentioned earlier. These controls are further divided into four parts:

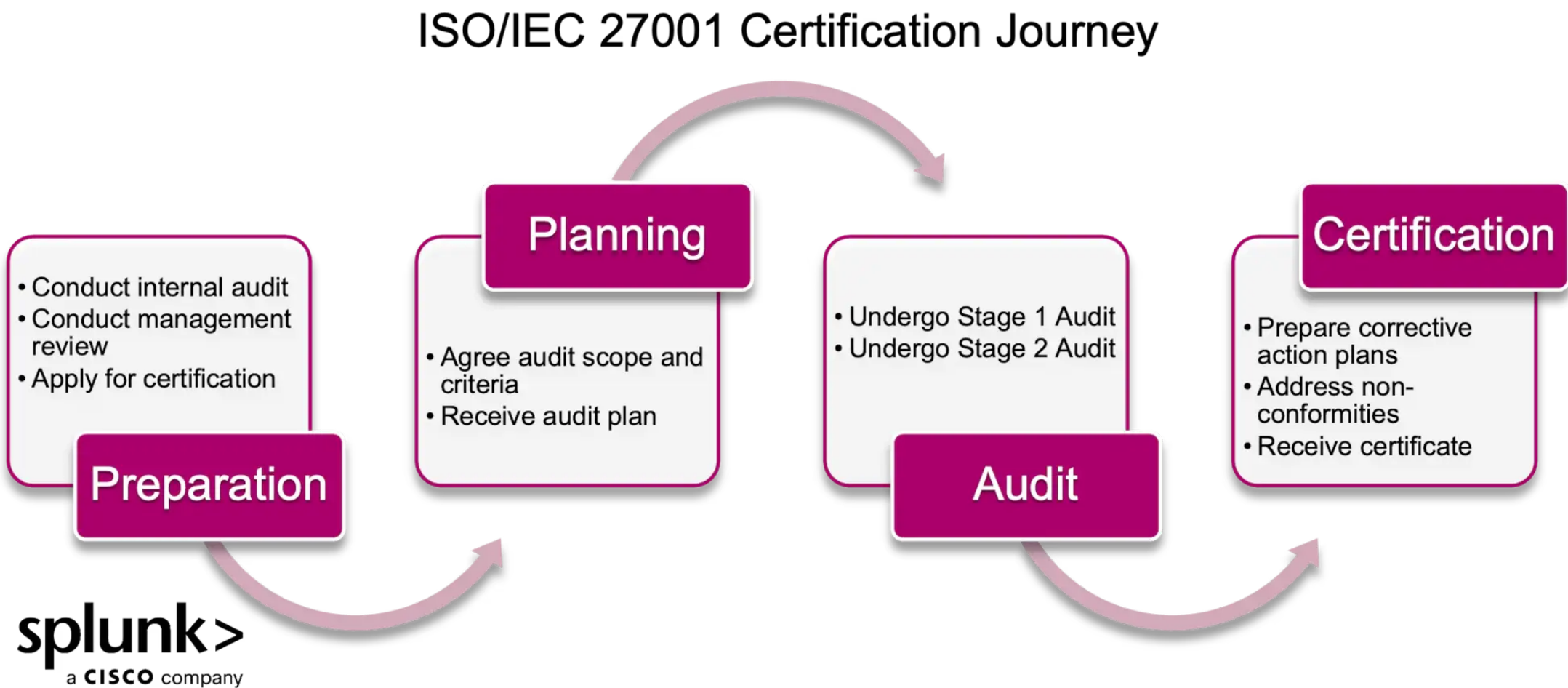
- **Organizational Controls (37)** for establishing information security policies, procedures, roles, and activities touching on the information lifecycle, projects, inventory, acceptable use, suppliers, incidents, compliance, and contact with authorities among others.
- **People Controls (8)** that concern individual people. These includes security measures during recruitment, training, disciplinary, exit, and remote working.
- **Physical Controls (14)** for handling the non-digital objects such as securing [office/data center premises](#), utilities, maintenance, and disposal activities.
- **Technological Controls (34)** for IT and communication controls necessary during the creation, use, storage, and transfer of information such as [access management](#), passwords, [encryption](#), malware, secure development, [network segregation](#), and user device security.

Becoming ISO/IEC 270001 certified

As with other ISO certifications, the ISO/IEC 27001 is desirable for organizations who want to demonstrate their seriousness with information security to their employees, suppliers, shareholders, regulators and other stakeholders.

But the journey to achieving certification is not a walk in the park — the ISMS has to meet the requirements spelled out in the standard *and* be tested to validate that the [actual security posture](#) matches what the organization claims.

There are four key phases that any entity goes through before achieving certification, let’s look at each phase.



Phase 1: Preparation

Phase 2: Planning

The certification body reviews the application and works with the organization to determine the audit scope based on the defined ISMS scope (see clause 4). Then the certification body will establish audit objectives and prepare an audit plan that outlines their approach to the audit including:

- The schedule
- Requirements to be audited

The organization uses the audit plan to prepare accordingly.

Phase 3: Audit

Next, the certification body's auditor(s) will execute the audit plan in two stages.

- **Stage 1** will review the ISMS documentation (which can be done remotely) to confirm readiness for the next stage. The documentation will include the internal audit results and management review meeting minutes.
- **The Stage 2 audit** follows a week or two later and is usually conducted onsite where the auditor(s) review records, conduct interviews, observe and test selected controls.

A formal audit report is issued detailing the level of conformance with the ISO/IEC 27001 requirements and details of any non-conformities identified.

Phase 4: Certification

If there are non-conformities, the organization will document corrective action plans and issue them to the certification body.

- For major non-conformities, the certification body's auditor(s) may require an onsite audit to validate the effectiveness of the corrective actions.
- Minor non-conformities usually do not require further audits.

Finally, once the certification body validates the corrective action plans as effective, they will proceed to issue an ISO/IEC 27001 certificate for the audited scope.

Three-year certification lifecycle

The ISO/IEC 27001 certificate is valid for three years. Successful recipients can market the certification on their website and official documentation. During this period, the certification body carries out annual surveillance audits to check that:

- The ISMS remains compliant and effective.
- The organization is adapting to new threats.

On the third year, the certification body conducts a recertification audit and issues a new certificate if successful.

Should major non-conformities persist without effective corrective measures, the certification body may withdraw the ISO/IEC 27001 certificate.

Note that the certification body can also withdraw the certificate if information on the lack of credibility of the organization's ISMS is made public. For example, if there are numerous complaints from customers or a statement from regulators regarding the poor state of information security within the organization.

Benefits of ISO/IEC 27001

As a body, ISO was founded with the idea of answering a fundamental question: "what's the best way of doing this?"

The global recognition of an ISO/IEC 27001 certification is first of an assurance to staff, suppliers, customers, regulators and other stakeholders of the organization's commitment to securing its own and their information through a best-in-class ISMS that is compliant to international standard requirements and is capable of handling all forms of cybersecurity threats.

Other benefits can be looked at in in two perspectives, financial and non-financial, as per [ISO/IEC TR 27016:2014](#) guidance. Some of the non-financial benefits include:

- Enabling the business to participate in high-risk endeavors.
- Enabling the business to satisfy legal and regulatory obligations.
- Managing customer and community expectations of the organization.
- Maintaining a trusted organizational reputation.

Organizations can also compute the economic benefits of implementing an ISMS that conforms to ISO/IEC 27001 requirements, including:

- Minimizing any negative impact to the organization's business objectives.
- Ensuring any financial loss is acceptable.
- Avoiding requirements for additional risk capital and contingency provisioning.



FAQs about ISO/IEC 27001

	Open all
What is ISO/IEC 27001?	⊕
Who should use ISO/IEC 27001?	⊕
What are the benefits of ISO/IEC 27001 certification?	⊕
How does ISO/IEC 27001 work?	⊕
What are the key components of ISO/IEC 27001?	⊕
How can an organization become ISO/IEC 27001 certified?	⊕
	Open all

See an error or have a suggestion? Please let us know by emailing splunkblogs@cisco.com.

This posting does not necessarily represent Splunk's position, strategies or opinion.



Simplify SecOps Compliance

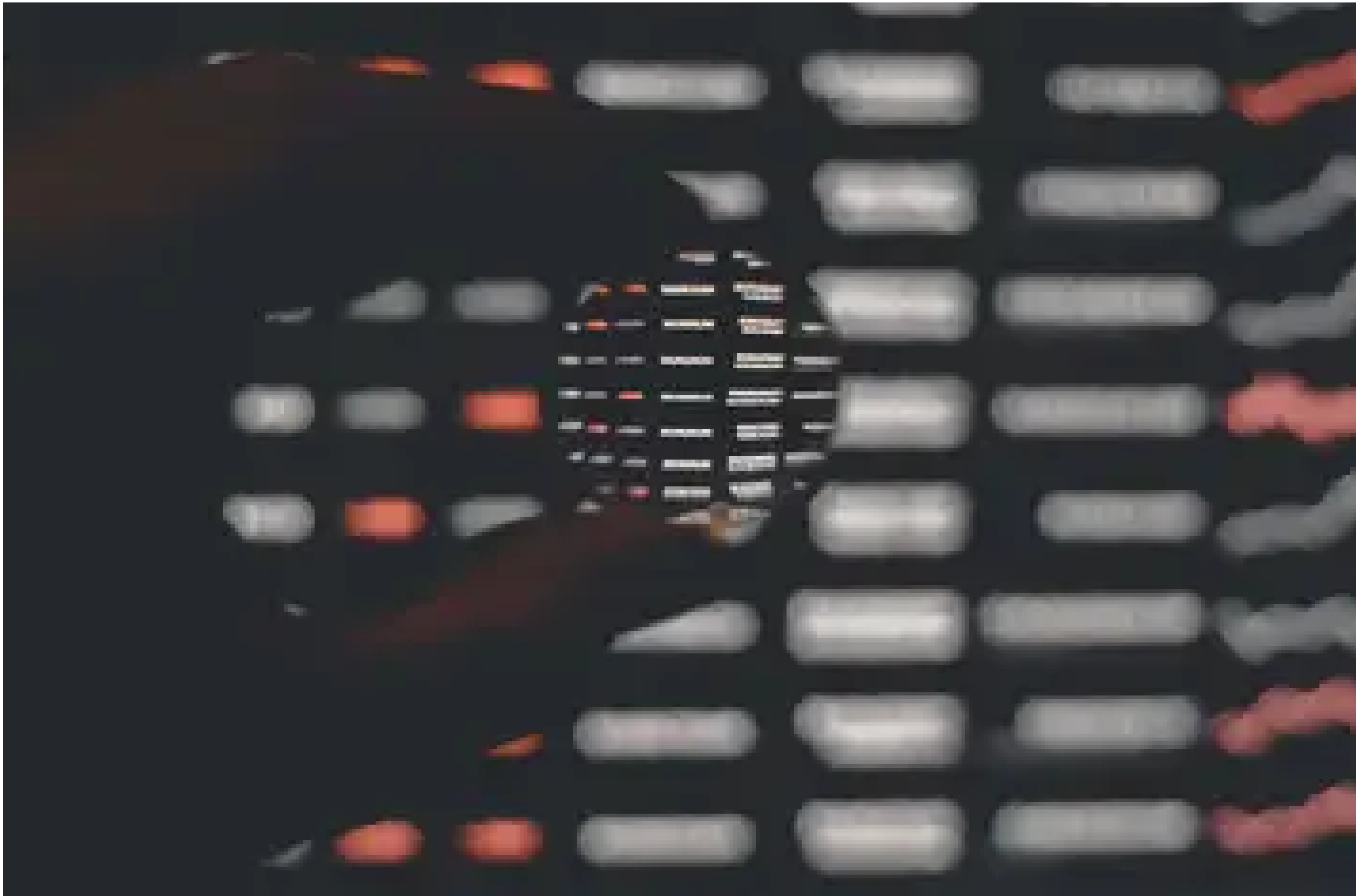
And boost operations! Close gaps, automate audits, and scale with ease.

[Learn how](#)



Joseph Nduhiu

Joseph is an ICT consultant and trainer with over 18 years of global experience across multiple sectors. His passion is assisting business units and IT departments in executing their digital transformation strategies and streamlining their operations in line with global standards and best practices. His areas of expertise include business process reengineering, IT service management, project management and cyber resilience. You can connect with Joseph [@josephnduhiu](#) and on [LinkedIn](#).



Learn 5 MINUTE READ

The Best Blockchain & Crypto Conferences in 2026

Explore the top blockchain and crypto conferences of 2026 for insights, networking, and the latest trends in Web3, DeFi, NFTs, and digital assets worldwide.



cyberattack.

Learn 6 MINUTE READ

What is BPA? Business Process Analytics, Explained

Discover how business process analytics (BPA) uses data-driven insights and technology to optimize workflows, boost efficiency, and improve business performance.

About Splunk





[Learn more about Splunk >](#)



Connect with Splunk on LinkedIn

[Follow @Splunk >](#)



Connect with Splunk on X

[Follow @Splunk >](#)



Connect with Splunk on Instagram

[Follow @Splunk >](#)



See Splunk Perspectives blog for execs

[Get Perspectives >](#)

COMPANY ▾

PRODUCTS ▾

SPLUNK SITES ▾

LEARN ▾

CONTACT SPLUNK ▾

USER REVIEWS ▾

LANGUAGES ▾



